

Exercise 06

Задача 1. Запись на стрижку.

1. Требования к паролям

Подход: умеренный (баланс UX и безопасности)

Состав пароля

- Минимальная длина: **8 символов**
- Не менее:
 - 1 буквы
 - 1 цифры
- Разрешены спецсимволы (необязательно)
- Запрет часто используемых паролей
- Запрет совпадения с email/телефоном

Смена и сброс пароля

- Смена — по инициативе пользователя
- Принудительная смена — раз в 12 месяцев (для менеджеров)
- Восстановление через:
 - Email-ссылку (одноразовая, срок 15 минут)
 - SMS-код (альтернативно)
- Ссылка одноразовая
- После смены — завершение всех активных сессий

2. Многофакторная аутентификация (MFA)

Подход: выборочная MFA

MFA требуется для:

- Менеджеров
- Изменения ролей
- Просмотра отчётов
- Начисления оплаты

Не требуется для:

- Клиентов при записи

Порядок аутентификации:

1. Ввод логина и пароля
2. Проверка данных
3. Отправка одноразового кода (SMS / email)
4. Подтверждение входа

3. Логирование

Операции, подлежащие логированию:

- Вход / выход
- Неудачные попытки входа (≥ 5 — блокировка 15 мин)
- Создание/отмена записи
- Изменение расписания
- Начисление оплаты
- Изменение ролей

Логируемые данные:

- User ID
- Роль
- IP-адрес
- Платформа (IOS, Android, Windows)
- Дата/время (UTC)
- Тип операции
- Статус (успешно/ошибка)
- Старое/новое значение (для изменений)

Хранение логов: **1 год**

Задача 2. Доставка заказов.

1. Требования к паролям

Подход: усиленный (финансы + мобильное приложение)

Состав пароля:

- Минимум **12 символов**
- Обязательно:
 - 1 заглавная буква
 - 1 строчная
 - 1 цифра
 - 1 спецсимвол
- Проверка на утечки
- История 5 предыдущих паролей
- Срок действия: 90 дней (диспетчер, админ)

Смена и восстановление:

- Восстановление только через:
 - SMS + одноразовый токен
- Ограничение 5 попыток
- После 5 ошибок — блокировка 30 минут
- Обязательный logout со всех устройств после смены

2. Многофакторная аутентификация (обязательная)

MFA требуется для:

- Входа диспетчера
- Входа администратора
- Начисления оплаты
- Переназначения заказа
- Изменения статуса «Доставлен»
- Доступа к финансовой информации

Порядок аутентификации:

1. Логин + пароль
2. Проверка устройства (device fingerprint)
3. Одноразовый пароль через:
 - Приложение-аутентификатор
 - SMS
4. Выдача токена доступа (срок 8 часов)

3. Логирование

Операции:

- Входы (успешные и неуспешные)
- Бронирование заказа
- Переназначение
- Изменение статуса
- Финансовые операции
- Изменение прав доступа
- Изменение персональных данных

Логируемые данные:

- User ID
- Роль
- Device ID
- IP
- Геолокация (для курьеров)
- ID заказа
- Старый/новый статус
- Timestamp (UTC)
- Результат операции
- ID операции (для трассировки)

Хранение логов: 3 года